



THREAT ADVISORY



**VULNERABILITY
REPORT**

**Input validation flaw in GitLab's Community and
Enterprise Software**

Date of Publication

August 24, 2022

Admiralty code

A1

TA Number

TA2022181

Summary

A remote code execution vulnerability that affects GitLab Community Edition (CE) and Enterprise Edition (EE) has been identified as CVE-2022-2884. It can be exploited using the GitHub import API, However it requires authentication to be triggered.

🔧 CVE Table

CVE	NAME	PATCH
CVE-2022-2884	Remote Command Execution via Github import	✓

🔧 Potential MITRE ATT&CK TTPs

TA0001 Initial Access	T1190 Exploit Public-Facing Application	TA0042 Resource Development	T1588 Obtain Capabilities
T1586 Compromise Accounts	TA0008 Lateral Movement	T1210 Exploitation of Remote Services	TA0004 Privilege Escalation
T1055 Process Injection	T1078 Valid Accounts	TA0002 Execution	T1569 System Services

Technical Details

The security weakness can be exploited via the GitHub import API due to insufficient input validation within the Import from GitHub API endpoint. A remote user can send specially designed data to the application, allowing it to run arbitrary instructions on the target system. Users can also protect themselves from the issue by disabling the GitHub import option.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-2884	Gitlab Community Edition: 11.3.4 - 15.3.0 & GitLab Enterprise Edition: 11.3.4 - 15.3.0	cpe:2.3:a:gitlab:gitlab:11.11.8:*:*:*:*:*:*	CWE-77

Patch Details

Update GitLab Community Edition and Enterprise Edition versions 15.3.1, 15.2.3, and 15.1.5 to address the issue

Reference

<https://about.gitlab.com/releases/2022/08/22/critical-security-release-gitlab-15-3-1-released/#Remote%20Command%20Execution%20via%20Github%20import>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

August 24, 2022 • 4:57 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com